ONE-PAGE BRIEF

Post-quantum cryptography review: lightwalletd @ 4abfe9cd7b9b

Client: Electric Coin Company (Zcash) — public repository (passive review) · Source: github.com/zcash/lightwalletd, commit `4abfe9cd7b9b` · Reviewed: 2026-11-04 18:58 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **0** High **2** Medium **1** Low **11** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 5 − 8 = 7 → **too late**

Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Medium QSI-2026-12170	**Quantum-vulnerable RSA key in certificate (lightwalletd.testnet.local)** What to do: Track in the PQC inventory; prefer short certificate lifetimes; follow CA/Browser Forum and NIST PQC transition guidance for ML-DSA...
Medium QSI-2026-12168	**Quantum-vulnerable RSA: role not determined (1 file(s))** preliminary What to do: Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form...
Low QSI-2026-12172	**golang.org/x/crypto v0.55.0 is affected by GO-2026-5932 (no severity rating)** preliminary What to do: Triage the advisory; upgrade to a fixed version (0.58.1-0.20261009181718-2f1f834330b2) if it applies.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium role not determined	RSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 10; unlikely to apply to this build: 9 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 1.

Analyst review: 0 confirmed, 1 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-23)

Static review of source code and manifests; files analysed: 34. No requests were sent to the owner's systems.

Full report, content SHA-256: `15c9ca3d8b1929b9f8bbc0f232d6fa91f7530eb49985b7063252d68f05cc6b20`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.